

Full Name: Sanjida Arefin

Student ID: 2023100000264

Serial Number (According to Attendance Sheet): 03

Course Name: Applied Penetration Testing Engineer: Hands-on Experience

Submission Date: 18 May 2026

External Penetration Testing Report

Assessment Overview

The assessment included the following activities:

- Active Reconnaissance
- OWASP Juice Shop Web Application Testing
- Windows Exploitation (Blue Room)

The testing was conducted in an authorized lab environment using tools such as Kali Linux, Nmap, Burp Suite, Metasploit Framework, and other standard penetration testing utilities.

Active Reconnaissance

Objective

The goal of the reconnaissance phase was to collect information about the target systems and identify exposed services, open ports, and potential entry points.

Process

During this phase, Nmap was used for host discovery and service enumeration. Several scan techniques were performed to gather detailed information about the target environment.

The scans identified multiple open ports and services, including HTTP, SMB, and RPC. Service enumeration also provided version information, which helped identify potentially vulnerable or outdated services.

Findings

The target system exposed several services publicly. SMB services were accessible externally, which increased the attack surface significantly. In addition, some services appeared to be outdated based on version fingerprinting results.

Security Impact

Exposed and outdated services provide attackers with valuable information about the environment and may allow them to identify known vulnerabilities.

If left unprotected, these services could lead to:

- Unauthorized access
- Information disclosure
- Remote code execution
- Lateral movement within the network

Recommendations

To reduce the identified risks, the following actions are recommended:

- Disable unnecessary services
- Restrict exposed ports through firewall rules
- Keep systems and services updated
- Limit public access to SMB services
- Implement network monitoring and intrusion detection systems

OWASP Juice Shop Assessment

Objective

The objective of the web application assessment was to identify common security vulnerabilities affecting the OWASP Juice Shop application.

Process

Burp Suite was configured as a proxy to intercept and analyze HTTP requests between the browser and the application. Authentication and input validation testing were performed during the assessment.

SQL Injection testing was conducted against the login functionality. By modifying login requests with crafted SQL payloads, authentication bypass was successfully achieved. The testing demonstrated that the application did not properly sanitize user input before processing SQL queries on the backend.

Findings

The assessment identified the following vulnerabilities:

- SQL Injection vulnerability
- Weak authentication controls
- Insufficient input validation
- Sensitive information exposure

Through SQL Injection, administrator-level access was obtained without valid credentials.

Security Impact

SQL Injection is a critical vulnerability because attackers may be able to:

- Bypass authentication mechanisms
- Access sensitive database information
- Modify or delete application data

- Escalate privileges
- Potentially gain access to the underlying server

Weak input validation further increases the risk of unauthorized access and application compromise.

Recommendations

The following mitigation measures are recommended:

- Use parameterized SQL queries
- Implement strong server-side input validation
- Sanitize all user inputs
- Deploy a Web Application Firewall (WAF)
- Conduct secure code reviews
- Strengthen authentication mechanisms
- Perform regular security assessments

Blue Room Exploitation

Objective

The objective of the Blue Room assessment was to identify and exploit vulnerabilities affecting a Windows machine in an authorized testing environment.

Process

The assessment started with Nmap scanning and SMB enumeration. The scans revealed that the target system was vulnerable to MS17-010, commonly known as EternalBlue. The Metasploit Framework was then used to configure and execute the EternalBlue exploit against the target machine. After successful exploitation, a Meterpreter shell session was established, providing remote administrative access. Post-exploitation activities included system navigation and retrieval of proof-of-access flags from authorized directories.

Findings

The target machine was vulnerable to:

- MS17-010 (EternalBlue)
- SMBv1 exposure

Successful exploitation resulted in remote code execution and complete compromise of the Windows system.

Security Impact

The EternalBlue vulnerability is considered highly critical because it allows attackers to execute arbitrary code remotely without authentication.

A successful attack could allow threat actors to:

- Deploy ransomware
- Gain full administrative access
- Steal sensitive information
- Move laterally across networks
- Disrupt business operations

Systems vulnerable to EternalBlue remain highly exposed to real-world cyberattacks.

Recommendations

The following security measures are strongly recommended:

- Apply Microsoft security patches immediately
- Disable the SMBv1 protocol
- Restrict SMB access using firewall rules
- Conduct regular vulnerability scans
- Implement Endpoint Detection and Response (EDR) solutions
- Maintain an effective patch management process

Overall Conclusion

The penetration testing engagement successfully identified multiple vulnerabilities affecting both the web application and Windows infrastructure environments. The assessment demonstrated how attackers can exploit weak configurations, outdated services, and insecure coding practices to gain unauthorized access and compromise systems.

The most critical findings included:

- SQL Injection vulnerabilities
- Weak authentication mechanisms
- MS17-010 EternalBlue vulnerability
- SMBv1 exposure

If exploited, these vulnerabilities could lead to:

- Unauthorized access
- Data breaches
- Full system compromise
- Malware deployment
- Service disruption

Implementing the recommended security controls, patch management practices, and secure development standards will significantly improve the organization's overall security posture and reduce the likelihood of successful cyberattacks in the future.